03 系统设计说明 SDD

版本 1.0 ·2026-09-27。系统为单组织现场零售模块化单体，前端 React/TypeScript/Vite、同源 Fastify API、MariaDB InnoDB。数据库只在容器内部网络开放。详见 架构图 与 交易序列图。

模块与部署

模块	职责	持久化
apps/web	角色导航、表单、服务器数据查询、错误及状态显示	不存认证令牌；已保存单据由服务器读取
auth.ts	Argon2id、会话、角色与 CSRF 校验	users、sessions、audit_events
catalog.ts	场地、活动、展位、商品、员工、班次	九核心实体中的六类主数据
inventory.ts	接收、确认调拨、版本盘点、余额	单据、余额、不可覆盖库存流水
sales.ts	草稿、占用、人工收款确认、成交、取消	sales、sale_lines、stock_holds 等
returns.ts	授权、部分退款、良品/损坏去向	returns、return_lines、负佣金
commissions.ts	正负计提、结算占用、付款登记	commission_*
db.ts/core.ts	同连接事务、整数金额、幂等命令、审计	idempotency_keys、audit_events

本地 Compose 有 db、一次性 migrate、app 三服务。随机数据库及首位管理员临时密码保存在 Docker 私有卷；app 只读到应用数据库密码，不挂载数据库 root 密码卷。migrate 用 root 账号建表后收紧运行账号权限。运行账号只对必要表有 UPDATE/DELETE 权限，库存、佣金、审计流水不授 UPDATE/DELETE。主机只发布 127.0.0.1:3000，MariaDB 不映射主机端口。通用 Dockerfile 和环境变量可迁移到用户以后选择的环境，本轮不包含云配置。

数据、状态与交易

九核心实体与 B 图对应关系见 数据库设计。活动 DRAFT → OPEN → CLOSED；班次 PLANNED → ACTIVE → CLOSED；销售 DRAFT → CHECKOUT → POSTED 或未成交取消；退货 DRAFT → AUTHORIZED → POSTED 或未完成取消；佣金结算 PREPARED → PAID 或未付款取消。完整状态源见 states.puml。

所有金额在服务层用 bigint 运算并以整数分保存。API 金额输入为 CAD 十进制字符串，输出金额字段为整数字符串；浏览器仅作格式化显示。每条销售明细保存成交单价、商品名/SKU、成本、底价、税率和佣金率快照。已过账历史不受后续主数据变更影响。

销售准备事务的顺序：幂等行 → 活动 → 班次/销售 → 商品 → 展位余额。事务内重读当前底价、费率、状态和可售量；只增加 reserved，保留 on_hand。确认成交在原 CHECKOUT 占用上使 on_hand 和 reserved 同量下降，写负库存流水、正佣金流水、销售时间与审计，最后一次提交。退货锁原销售及明细，按累计退数分摊原税/佣金；良品加回指定库位，损坏品不加可售。佣金准备锁员工并占用全部未结流水，支付登记不执行转账。

事务使用同一连接，隔离级别 READ COMMITTED，关键行使用 FOR UPDATE；死锁、锁等待及 MariaDB 并发读取冲突在回滚后最多重试三次。任意业务 POST 需要 Idempotency-Key UUID，命令键与请求摘要及响应和业务数据在同一事务提交。相同键不同内容返回 409。外部收款与退款动作不在数据库事务内，也不由系统发起。

API 与安全

API 前缀 /api/v1，采用 JSON。关键路径：/auth/*、/venues、/events、/booths、/products、/salespeople、/shifts、/stock/*、/sales、/returns、/commissions/*、/reports/sales、/audit。详见 OpenAPI 合同。错误统一 {code,message,requestId}，已识别输入/状态/权限错误为 400/401/403/404/409；500 不回 SQL 栈。

登录令牌为 32 字节安全随机数，数据库只存 SHA-256 摘要；Cookie 为 HttpOnly、SameSite=Lax、Path=/。本地 HTTP Secure=false；迁移到 HTTPS 时必须配置 COOKIE_SECURE=true 和准确 PUBLIC_ORIGIN。会话 12 小时绝对过期、30 分钟空闲过期；改密及停用撤销旧会话。写请求核对 CSRF 与可用的 Origin。OWNER 才能管理主数据、库存、退款、结佣和审计；销售员查询由服务器按 salesperson_id 限定，销售明细不返回批发成本，报表不返回可反推成本的毛利字段。

Cache-Control: no-store 用于 API；响应设置 CSP、frame-ancestors、no-sniff。动态报表维度白名单，SQL 参数化；CSV 文本字段预防公式解释。开发环境不提供自助注册与角色自选。MariaDB 连接串、课程原件和私有备份不进入发布 ZIP。

ADR

编号	决策
ADR-01	MariaDB 11.8 LTS + 版本化 SQL
ADR-02	单进程 Fastify + 同源 React
ADR-03	整数分与原单快照
ADR-04	先占用再确认线下收款
ADR-05	本地随机初始密码卷

明确边界

V1 不处理线上支付、自动退款或发工资；不做多币种、多组织、离线确认成交、采购会计总账。标准成本毛利只估算商品成本，不包括活动费用、人工和差旅。当前版本使用单时区 America/Toronto，不支持跨时区门店。